

Deferred Asynchronous Post-Quantum Signature Verification for Low-Latency TLS 1.3 Handshakes

Tahera Begum Abdul^{a,*}, K. Venkata Ramana^a

^a*Department of Computer Science and Systems Engineering, Andhra University, Visakhapatnam, Andhra Pradesh, India*

Abstract

Migrating TLS 1.3 server authentication to post-quantum (PQ) signatures is urgent not because recorded traffic can be decrypted later—that threat is addressed by hybrid key exchange—but because public-key infrastructures take many years to migrate and must be quantum-safe *before* a cryptographically relevant quantum computer can forge classical signatures in real time. During the transition, many deployments are expected to use hybrid authentication, in which a classical (ECDSA) and a PQ (ML-DSA or FN-DSA) signature must both verify. This paper studies one component of the resulting handshake cost: the client-side verification of the PQ signature component.

We study *Deferred Asynchronous PQ Verification* (DAPV), a client-side, implementation-level change to the TLS 1.3 handshake state machine that requires no change to the wire format or to the server. The classical component is verified synchronously and the handshake completes in a PROVISIONAL state; the PQ components, already bound into the handshake transcript, are verified by background workers, after which the session is promoted to FULLY_AUTHENTICATED or terminated. We specify the semantics of the provisional state (permitted data, session tickets, alerts, and an application-facing API) and evaluate DAPV in OpenSSL 3.5 with the Open Quantum Safe provider, using three-certificate hybrid chains, X25519MLKEM768 key exchange, and client and server in separate network namespaces on disjoint CPU cores, joined by an emulated 1500-byte-MTU link. Over more than 20,000 handshakes, deferral does not measurably reduce handshake latency for P-256 + ML-DSA-44, P-256 + FN-DSA-512 or P-384 + ML-DSA-65 (median change within ± 0.2 ms at RTTs of 0–150 ms), because each PQ verification costs only 37–59 μ s; a thread-per-job implementation is slower than synchronous verification. Deferral pays off only when verification is expensive: for P-256 + SLH-DSA-128f it saves 1.6 ms (13.5%) at zero RTT. It does not increase server throughput. With a bounded worker pool, the provisional window is 0.08 ms at the median and 0.42 ms at the 99th percentile for ML-DSA-44. The measurements also confirm that hybrid chains add round trips exactly when the server’s flight exceeds the TCP initial congestion window (one extra for ML-DSA-65, two for SLH-DSA-128f). Finally, we bound the data that can be exposed during the provisional window, identify a denial-of-service vector specific to deferred verification, and give mitigations.

Keywords: Post-quantum cryptography, TLS 1.3, Hybrid authentication, Deferred verification, ML-DSA, FN-DSA, Handshake latency

1. Introduction

1.1. Why post-quantum authentication, and why now

The public-key algorithms used by TLS today—ECDH/X25519 for key exchange and RSA or ECDSA for authentication—rely on the hardness of integer factorisation and discrete logarithms, both of which are solved efficiently by Shor’s algorithm [1] on a sufficiently large quantum computer. The two uses of public-key cryptography in TLS, however, face quantum threats of a different nature and urgency.

Confidentiality is threatened today by the “harvest now, decrypt later” (HNDL) strategy [2]: an adversary records encrypted sessions now and recovers their key-exchange secrets once a cryptographically relevant quantum computer (CRQC) exists. HNDL is countered by post-quantum or hybrid key exchange such as X25519MLKEM768 [3, 4], which major browsers and content delivery networks have already deployed [5]. *Authentication* is not vulnerable to HNDL: a signature that was verified in a past handshake cannot be retroactively forged to affect that handshake. The quantum threat to authentication is instead *active* impersonation once a CRQC can forge server signatures in real time. Why, then, migrate authentication now? Because the systems that carry authentication—certificate authorities, root programmes, hardware security modules, device firmware with pinned trust anchors, and certificates with multi-year validity—take many years to change. By Mosca’s inequality [6], if the migration

*Corresponding author

Email address: taherabegum.abdul@gmail.com (Tahera Begum Abdul)

time plus the lifetime of deployed trust anchors exceeds the time until a CRQC appears, migration must begin now. National agencies have therefore published timelines covering both key establishment and signatures [7, 8, 9], following NIST’s standardisation of ML-DSA [10], SLH-DSA [11] and the forthcoming FN-DSA [12].

This paper is concerned only with the authentication side. We state this explicitly because the two problems are often conflated: nothing in this paper mitigates HNDL, and our experiments are therefore designed so that the key-exchange configuration is held fixed across all measured variants (Section 5.4).

1.2. Hybrid authentication and its costs

During the transition, a server may authenticate with a classical signature, a PQ signature, or both. *Hybrid* authentication—in which the client accepts the server only if both a classical and a PQ signature verify—is recommended by several agencies as a hedge: the PQ schemes are young, and some candidates (e.g., Rainbow and SIKE) were broken late in the NIST process, while ECDSA remains secure against classical adversaries. Under an AND-combination, an attacker must break *both* components [13, 14]. Hybrid authentication is thus a security measure; it is *not* an interoperability mechanism. A hybrid credential in a single certificate (a *composite* key [15]) cannot be verified by a client that does not understand the composite algorithm; interoperability with such clients requires that the server select among several certificate chains using the `signature_algorithms` extension, or that the certificate carry the PQ key in a non-critical extension that legacy clients ignore [13]. Section 2.2 reviews these options and explains which of them DAPV applies to.

The cost of PQ authentication is dominated by size. An ML-DSA-44 public key and signature are 1312 and 2420 bytes, respectively, against 65 and at most 72 bytes for ECDSA P-256 (Table 1). A hybrid server flight carries at least two PQ signatures (one in the leaf certificate and one in `CertificateVerify`) plus one PQ public key; with an intermediate certificate, it carries one more of each. When the flight exceeds the TCP initial congestion window (typically ten segments, about 14.6 KB [16]), an additional round trip is required, which is the principal cause of the latency increases and throughput reductions reported in the literature [17, 18, 19, 20]. Size-reduction techniques (certificate compression, intermediate-certificate suppression [21, 22], mixed certificate chains [23], KEM-based authentication [24, 25]) address that component.

The second, smaller, component is computation. A hybrid client performs one classical and one PQ verification for `CertificateVerify`, and one of each for every certificate signature in the chain, all synchronously on the handshake critical path. DAPV targets this component *only*: it does not reduce the number of bytes on the wire and does not remove any fragmentation- or congestion-window-induced round trip.

1.3. Research question and approach

PQ signature verification is fast on processors with vector extensions—we measure 37–59 μ s per ML-DSA or FN-DSA verification with AVX2 (Section 6.2). The question we ask is therefore not “is PQ verification slow?” but: *if the PQ components of a hybrid credential are verified after, rather than before, the handshake completes, what latency and throughput changes are observed in a real TLS stack, for which schemes, and what security exposure does the deferral create?* DAPV answers the first part by verifying the classical component synchronously (which yields ordinary classical authentication immediately) and verifying the PQ components in background workers, while the handshake transcript—which already contains the PQ signature bytes—binds the deferred checks to the session.

1.4. Contributions

We deliberately position DAPV as an *implementation-level* scheduling strategy with precisely specified local state semantics, not as a new TLS protocol mechanism: it changes neither messages nor the wire format, and a DAPV client interoperates with unmodified servers. Our contributions are:

- (1) **Provisional-state semantics.** A specification of the client state machine with a PROVISIONAL state: entry and promotion conditions, the behaviour on failure (alert and teardown), handling of session tickets, resumption and 0-RTT, and an application-facing API to enforce a data cap (Sections 4 and 7.4).
- (2) **Implementation.** DAPV in OpenSSL 3.5 via a 32-line hook in the OQS provider, with thread-per-job and bounded-pool worker models, deferring all PQ verifications of a handshake (chain and `CertificateVerify`) (Section 5.1).
- (3) **Evaluation.** Latency, provisional-window duration and completed-handshake rate for four hybrid schemes with three-certificate chains and X25519MLKEM768, five RTTs, two worker models and two CPU placements, with client and server separated by network namespaces, disjoint cores and an emulated link (Section 6). The main finding is negative for the lattice schemes: deferral helps only when PQ verification is expensive.
- (4) **Risk characterisation.** A bound on data exposed during the provisional window that accounts for both link rate and TCP congestion window, a DAPV-specific denial-of-service vector, and mitigations (Section 7).

Table 1: Sizes (bytes) of the objects that appear in a TLS 1.3 handshake for the algorithms discussed. Values from the respective standards.

Algorithm	Security category	Public key	Signature / ciphertext
ECDSA P-256	classical	65	≤ 72
FN-DSA-512 (Falcon)	1	897	≈ 666
ML-DSA-44	2	1312	2420
ML-DSA-65	3	1952	3309
SLH-DSA-SHA2-128s	1	32	7856
X25519MLKEM768 (key exchange)	3	1216 (client share)	1120 (server share)

1.5. Scope and limitations

DAPV requires a classical component to provide the synchronous anchor for the provisional state; PQ-only deployments are out of scope. During the provisional window the session has classical-strength authentication only, so DAPV is unsuitable wherever even a bounded interval of classical-only authentication is unacceptable. Our testbed separates client and server by network namespaces and disjoint CPU cores on one virtual machine rather than by physical hosts; the implications are discussed in Section 6.4.

Section 2 gives the background on PQ signatures, hybrid constructions and TLS 1.3 authentication, and Section 3 reviews related work. Section 4 presents the design, Section 5 the experimental setup and Section 6 the results. Section 7 analyses security, Section 8 discusses deployment and Section 10 concludes.

2. Background

2.1. Post-quantum signature schemes

A signature scheme is *post-quantum* if its security rests on problems for which no efficient quantum algorithm is known, as opposed to factoring and discrete logarithms. NIST has standardised three families:

- **ML-DSA** (FIPS 204, formerly CRYSTALS-Dilithium) [10]: a Fiat–Shamir-with-aborts scheme based on the Module-LWE and Module-SIS lattice problems. Signing and verification use only integer arithmetic and the NTT, are simple to implement in constant time and vectorise well (AVX2 implementations are part of the reference package [26]). Signatures and keys are comparatively large.
- **FN-DSA** (FIPS 206, formerly Falcon; draft at the time of our experiments) [12]: a hash-and-sign scheme over NTRU lattices. It has the smallest combined public key and signature of the standardised schemes and fast verification, but signing requires floating-point Gaussian sampling, which complicates constant-time implementation.
- **SLH-DSA** (FIPS 205, formerly SPHINCS+) [11]: a stateless hash-based scheme whose security relies only on properties of the hash function. It has tiny public keys but signatures of 7.8–50 KB and markedly slower signing and verification.

Choosing among them is a trade-off between size (which drives network cost), verification speed (which drives client CPU cost), signing speed and implementation risk (which drive server cost and side-channel exposure), and the conservativeness of the security assumption. For TLS server authentication, where every handshake transmits the leaf public key and at least two signatures, ML-DSA-44 and FN-DSA-512 are the most commonly evaluated options; we use both. Table 1 lists the object sizes relevant to this paper.

2.2. Hybrid signature constructions

A hybrid (or *multi-algorithm*) authentication combines a classical and a PQ signature so that security holds while at least one of them is unbroken [13, 14, 27]. Four constructions are relevant to TLS:

- Concatenation / composite.** A single composite public key and a signature $\sigma = \sigma_E || \sigma_P$ under a new algorithm identifier, as in the IETF LAMPS composite ML-DSA specification [15]. Simple, but not backward compatible: a client that does not recognise the composite algorithm cannot verify it. Without further measures, a concatenation is *separable*—an attacker can strip one component and present the other as a stand-alone signature—which composite specifications prevent by binding the algorithm identifier into the signed message [14, 15].
- Nested / alternative-signature extensions.** A classical certificate that additionally carries a PQ key and PQ signature in non-critical X.509 extensions, so that legacy verifiers ignore them [13]. Backward compatible, at the cost of carrying both sets of objects to every client.

- (c) **Parallel certificate chains.** The server holds a classical and a PQ chain and selects one per client using `signature_algorithms`. Interoperable, but each client verifies only one algorithm, so it is not hybrid in the AND sense.
- (d) **Mixed chains.** Different algorithms at different levels of the chain [23], e.g., a PQ root and intermediate with a classical leaf, trading size against the level at which quantum resistance is achieved.

DAPV applies whenever a single client must verify both a classical and a PQ signature on the same handshake, i.e., to (a) and (b), and to the PQ-signed levels of (d). It does not apply to (c). Our prototype uses a concatenation encoding (Section 5.1); it is not claimed to satisfy the non-separability properties of the composite specification [15], which a production deployment should adopt. We note that DAPV’s own design makes stripping of σ_P yield at most a provisional session, because the client never promotes a session without a valid σ_P .

2.3. TLS 1.3 authentication

TLS 1.3 [28] supports three ways of authenticating a peer.

- (i) **Certificate-based authentication** in a full handshake. After `ServerHello` establishes handshake traffic keys, the server sends, encrypted, `EncryptedExtensions`, `Certificate` (its chain), `CertificateVerify` and `Finished`. The client validates the chain to a trust anchor, which requires verifying the signature on each certificate issued by a CA in the chain, and verifies `CertificateVerify`: a signature, under the leaf key, over 64 bytes of 0x20, the context string “TLS 1.3, server `CertificateVerify`”, a zero byte and the transcript hash of all handshake messages up to and including `Certificate`. The server `Finished` is an HMAC over the transcript up to and including `CertificateVerify`; the client `Finished` is an HMAC over the transcript up to and including the server `Finished`. A failed `CertificateVerify` check must terminate the handshake with a `decrypt_error` alert; an invalid chain with `bad_certificate` or a related alert.
- (ii) **PSK-based authentication** (session resumption or an external PSK). No certificate or signature is exchanged; authentication is inherited from the session that issued the ticket (or from the external key). With 0-RTT, the client may send early data under the PSK before the server’s first flight; such data is not forward secret and is replayable.
- (iii) **Post-handshake client authentication**, in which the server requests a client certificate after the handshake.

The client may also be authenticated with a certificate during the main handshake (mutual TLS), in which case the *server* performs the verification. DAPV applies to certificate-based authentication in full handshakes (i). For (ii) there is no signature to defer, but resumption must be restricted so that it does not inherit a provisional authentication (Section 4.3). In mutual TLS, the same technique could be applied by the server to the client’s hybrid signature; we do not evaluate this case.

Our implementation defers the PQ component of *every* hybrid verification the client performs: the signatures on the leaf and intermediate certificates of the chain and the `CertificateVerify` signature, i.e., three PQ verifications per handshake with a three-certificate chain (root, intermediate, leaf; the root is the client’s trust anchor and is not sent).

3. Related Work

PQ performance in TLS. Paquin, Stebila and Tamvada [19] benchmarked PQ key exchange and signatures in TLS under emulated network conditions and showed that the effect of size dominates that of computation as packet loss and RTT grow. Sikeridis, Kampanakis and Devetsikiotis [17] studied PQ authentication in TLS 1.3 specifically, showing that the added round trip caused by exceeding the TCP initial congestion window is the main source of slowdown and that verification cost is small; they later extended the analysis to TLS and SSH [18]. Sosnowski et al. [29] and Montenegro et al. [20] report evaluation frameworks and results across classical, hybrid and PQ configurations with OpenSSL and OQS. These studies measure costs; none proposes changing *when* verification is scheduled.

Reducing authentication size. KEMTLS replaces handshake signatures by KEM-based implicit authentication [24], with a variant using pre-distributed keys [30] and an IETF draft [25]; Gonzalez and Wiggers evaluated it on embedded devices [31]. Intermediate-certificate suppression [21, 22] and mixed chains [23] reduce the number of large objects transmitted. These approaches attack the dominant, size-related cost and are complementary to DAPV, which attacks the computational one; with them in place, the relative importance of computation increases.

Hybrid signatures. Bindel et al. [13] formalised hybrid signatures for PKI transition and analysed nested and concatenated combinators; Bindel and Hale [14] and the IETF hybrid-signature spectrum document [27] classify separability and backward-compatibility properties; composite ML-DSA is being standardised in the IETF LAMPS working group [15].

Asynchronous and early-data processing in TLS. Deferring or overlapping cryptographic work with the handshake has precedents. OpenSSL’s asynchronous mode and the QTLS framework [32] offload RSA/ECC operations to accelerators and resume the handshake on completion; this overlaps work *across* connections but keeps each connection blocked until its operation completes, whereas DAPV lets a connection proceed before its PQ verification completes. TLS False Start [33] allowed a TLS 1.2 client to send application data before receiving the server **Finished**, accepting a bounded risk in exchange for one round trip; TLS 1.3 0-RTT similarly trades replay protection for latency [28]. DAPV follows the same pattern—accept a weaker guarantee for a bounded time, under explicit restrictions on what may be sent—applied to the PQ component of authentication.

Formal analysis of deferred authentication. Cremers et al. [34] found an attack on an early draft of TLS 1.3 delayed client authentication that arose because the delayed signature was not bound to the full session transcript; the final TLS 1.3 design and its symbolic analysis [35] ensure such binding. In DAPV the deferred signature is part of **CertificateVerify**, which is included in the transcript authenticated by both **Finished** messages before any application data is sent (Section 4.4). A formal model of the provisional state is future work.

Industrial deployment. Google’s CECPQ1 and CECPQ2 experiments [36, 37, 38] and Cloudflare’s experiments [5] concerned PQ key exchange, which is now widely deployed. Deployment of PQ authentication is at an earlier stage and its size cost is the main obstacle discussed [39, 40].

4. DAPV Design

4.1. Design goals

DAPV is designed to (G1) remove the verification of the PQ component from the client’s handshake critical path; (G2) never promote a session to full authentication unless the PQ component has verified, and terminate the session if it fails; (G3) bound what the application may send before promotion; and (G4) require no change to the server, the messages or the wire format, so that a DAPV client interoperates with any server offering the same hybrid credential. Non-goals are reducing handshake size or round trips, and PQ-only deployments.

4.2. Handshake flow

Figure 1 shows a full TLS 1.3 handshake with DAPV on the client. The numbered steps are:

1. **ClientHello**: the client offers key-exchange groups and, in **signature_algorithms**, the hybrid algorithm.
2. **ServerHello**: the server selects the group; both sides derive handshake traffic keys. All following server messages are encrypted.
3. **EncryptedExtensions, Certificate, CertificateVerify, Finished**: the server sends its chain and the hybrid signature $\sigma_E \parallel \sigma_P$ over the transcript, followed by its **Finished**. The transcript hash now covers σ_P .
4. **Classical verification**: the client validates the chain’s classical signatures and verifies σ_E synchronously. On failure it sends the corresponding fatal alert and aborts; no PQ work is scheduled.
5. **Dispatch**: the client submits the job (pk_P, m, σ_P, sid) to a verification worker and enters PROVISIONAL. Here m is the **CertificateVerify** content defined in Section 2.3.
6. **Client Finished**: the client verifies the server **Finished**, sends its own **Finished** and derives the application traffic keys. The handshake is complete from the server’s point of view, and application data may flow subject to the policy of Section 4.3.
7. **PQ verification**: the worker verifies σ_P . Δt is the time from step 5 to the end of this step; it consists of queueing and scheduling delay plus the verification itself.
8. **Promotion or termination**: on success the session becomes FULLY_AUTHENTICATED; on failure the client sends a fatal **decrypt_error** alert, closes the connection, and discards all state derived from the session, including tickets (Section 4.3).

4.3. Provisional-state semantics

Promotion does not re-key. The transition from PROVISIONAL to FULLY_AUTHENTICATED changes only a local state variable; no message is exchanged and the traffic keys are not changed. Re-keying is unnecessary because the keys depend only on the (EC)DHE/KEM shared secret and the transcript, both fixed at step 6; the PQ verification adds assurance about *who* holds those keys, not about the keys themselves. If σ_P verifies, the peer with whom the keys were established during Δt is the same peer that is now fully authenticated, so data sent during Δt is retroactively covered by the full hybrid guarantee. If it fails, that data may have been sent to an impostor who defeated only the classical component; this is the exposure bounded in Section 7.2. A TLS **KeyUpdate** after promotion is permissible but adds no authentication.

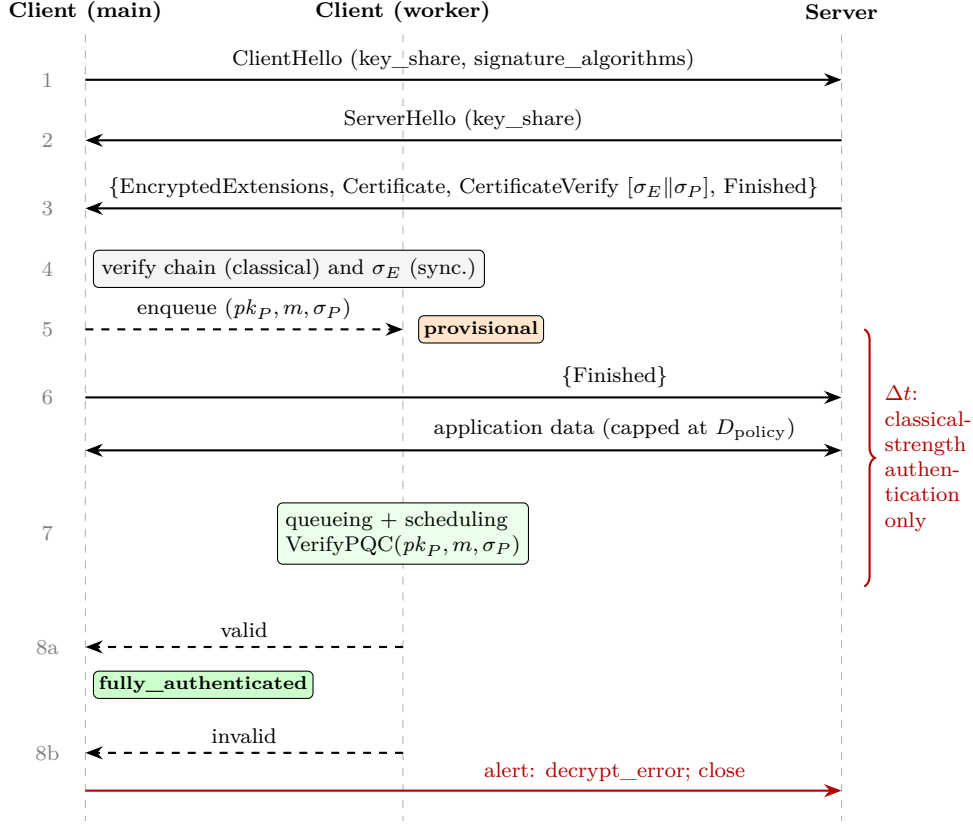


Figure 1: TLS 1.3 full handshake with DAPV on the client. Messages in braces are encrypted under handshake traffic keys. σ_P is part of **CertificateVerify** and hence of the transcript authenticated by both **Finished** messages (step 3 onwards), so the deferred check in step 7 necessarily concerns the signature received in this handshake. No message is added or changed; steps 4–8 are local to the client.

Data policy. While **PROVISIONAL**, the application may send at most D_{policy} bytes and should send only data it would be willing to reveal to a classical-only authenticated peer (Algorithm 3). Received data may be processed but should not trigger irreversible actions.

Tickets, resumption and 0-RTT. Because PSK resumption inherits the authentication of the issuing session, a **NewSessionTicket** received while **PROVISIONAL** must be held and made usable only on promotion, and discarded on failure. Otherwise an attacker who passed only the classical check could obtain a ticket whose resumptions—including 0-RTT early data—never undergo PQ verification.

Failure. On PQ failure the client sends a fatal **decrypt_error** alert (the alert TLS 1.3 prescribes for a failed **CertificateVerify**), closes the connection, marks the peer’s credential as failed for the lifetime of the process, and reports the failure to the application.

4.4. Transcript binding

The server **Finished** MAC covers **CertificateVerify** and therefore σ_P ; the client verifies it before step 6. An attacker therefore cannot substitute σ_P with a signature from another session, or modify it in transit, without causing the server **Finished** check to fail. Binding guarantees *which* signature is verified later; it does not by itself guarantee that the signature is *valid*, which is precisely what step 7 checks.

4.5. Algorithms

Algorithm 1 gives the client procedure. **VerifyECDSA** and **VerifyPQC** denote the verification algorithms of ECDSA P-256 and of the PQ scheme (ML-DSA.Verify of FIPS 204 [10] or FN-DSA verification [12]), each applied to the corresponding component public key pk_E , pk_P from the leaf certificate, the message m of Section 2.3 and the corresponding signature component; each returns a Boolean.

Dispatch order: after, not concurrently with, the classical check. Two reasons. First, dispatching only after σ_E has verified ensures that a peer who cannot produce a valid classical signature cannot cause any PQ work or occupy a worker; dispatching first would let an unauthenticated attacker consume workers at the cost of a single message, strengthening the flooding attack of Section 7.3. Second, the classical verification takes tens of microseconds, so starting the PQ job earlier would shorten Δt by at most that amount. Implementations that prefer to overlap the two can dispatch first and cancel the job if σ_E fails.

Algorithm 1: DAPV client processing of a hybrid `CertificateVerify`

Input: Leaf keys (pk_E, pk_P) ; message m ; signature $\sigma_E \parallel \sigma_P$; session id sid

```
1 if not VerifyECDSA( $pk_E, m, \sigma_E$ ) then
2   | send alert decrypt_error; abort // no PQ work is scheduled
3 Submit( $pk_P, m, \sigma_P, sid$ ) to the worker pool (Algorithm 2)
4  $session.state \leftarrow$  PROVISIONAL
5 verify server Finished; send client Finished; derive application traffic keys
6 on completion of job ( $sid, ok$ ):
7   | if  $ok$  then
8     |  $session(sid).state \leftarrow$  FULLY_AUTHENTICATED; release held session tickets
9   | else
10  | send alert decrypt_error; close  $session(sid)$ ; discard held tickets
```

Algorithm 2: Bounded verification worker pool (recommended design; the evaluated with $M = 2$ alongside a thread-per-job variant, Section 5.1)

Input: Pool size M ; queue capacity Q

```
1 start  $M$  worker threads, each executing:
2 while running do
3   | ( $pk_P, m, \sigma_P, sid$ )  $\leftarrow$  BlockingDequeue()
4   |  $ok \leftarrow$  VerifyPQC( $pk_P, m, \sigma_P$ )
5   | notify the owning connection of ( $sid, ok$ )
6 function Submit( $pk_P, m, \sigma_P, sid$ ):
7   | if queue length  $< Q$  then
8     | enqueue the job
9   | else
10  | verify synchronously on the caller's thread // back-pressure
```

4.6. Design rationale: threads versus instruction-level parallelism

A natural question is why DAPV uses a separate thread when PQ verification is already fast and vector instructions (AVX2, AVX-512) accelerate it further. The two techniques are complementary rather than alternatives. SIMD reduces the *duration* of one verification and is already used by our prototype (liboqs AVX2 code paths). Thread-level deferral changes *where* the remaining duration is spent: off the handshake critical path. For a single AVX2 ML-DSA-44 verification the remaining duration is about $37 \mu s$, and deferring it cannot save more than that; our measurements confirm that for the lattice schemes the saving is within measurement noise (Section 6.1).

Deferral becomes worthwhile when the synchronous PQ work on the critical path is large, which happens when (i) the chain contains several PQ-signed certificates, possibly with PQ-signed certificate-transparency timestamps, so that a handshake needs several PQ verifications; (ii) a slower scheme such as SLH-DSA is used; (iii) the client lacks vector units (microcontrollers, low-end ARM cores); or (iv) the credential combines more than two algorithms (e.g., ECDSA + ML-DSA + SLH-DSA). Cases (i) and (iv) consist of *independent* verifications, which SIMD cannot parallelise with one another but a worker pool can, one per core. Algorithm 1 generalises directly: all PQ components are submitted as separate jobs and the session is promoted when all have succeeded. Our evaluation covers cases (i) and (ii): three-certificate chains, in which every handshake performs three PQ verifications, and SLH-DSA-128f (Section 6.1); cases (iii) and (iv) remain future work.

4.7. Analytical model

Let k be the number of round trips of the handshake (one for a TLS 1.3 full handshake as seen by the client) and L_0 the RTT-independent processing time. Then

$$L = L_0 + (k + \delta k) \text{RTT}, \quad (1)$$

where $\delta k \geq 0$ counts additional round trips, which occur when the server's first flight exceeds the sender's congestion window (initially about ten segments [16]), *not* merely when a message spans several segments: segments within the window are sent back to back. DAPV removes the synchronous PQ-path time T_{PQ} from L_0 and leaves δk unchanged:

$$L_{\text{DAPV}} = (L_0 - T_{PQ}) + (k + \delta k) \text{RTT}. \quad (2)$$

Algorithm 3: Application-layer data policy

Input: Session state; bytes already sent while provisional s ; payload size d ; cap D_{policy}

```
1 if  $state = \text{PROVISIONAL}$  and  $(s + d > D_{\text{policy}}$  or  $payload\ is\ sensitive)$  then  
2   | buffer payload until FULLY_AUTHENTICATED (or drop on failure)  
3 else  
4   | transmit payload; if  $state = \text{PROVISIONAL}$  then  $s \leftarrow s + d$ 
```

Consequently the saving is an RTT-independent offset, T_{PQ} , and the curves of synchronous and DAPV latency against RTT have equal slope. The server’s first flight comprises `ServerHello` (1120-byte X25519MLKEM768 share), the encrypted `EncryptedExtensions`, `Certificate`, `CertificateVerify` and `Finished`. With the three-certificate chains used in Section 6, its size is dominated by the leaf and intermediate certificates (DER sizes 0.9, 4.0, 8.4, 11.6 and 35.2 KB for P-256, P-256 + FN-DSA-512, P-256 + ML-DSA-44, P-384 + ML-DSA-65 and P-256 + SLH-DSA-128f) plus the `CertificateVerify` signature (0.07, 0.7, 2.5, 3.4 and 17.1 KB). Against an initial window of ten 1448-byte segments (14.5 KB), the model predicts $\delta k = 0$ for P-256, FN-DSA-512 and ML-DSA-44, $\delta k = 1$ for ML-DSA-65 (≈ 16 KB) and $\delta k = 2$ for SLH-DSA-128f (≈ 54 KB, which needs three slow-start windows of 14.5, 29 and 58 KB). Section 6.1 confirms all five predictions.

5. Implementation and Experimental Setup

5.1. Implementation

We implemented DAPV on OpenSSL 3.5.4, liboqs 0.14.0 (built with AVX2 optimisations) and oqs-provider 0.10.0 [41]. OpenSSL 3.5 provides ML-KEM and the X25519MLKEM768 group natively; the OQS provider supplies the hybrid signature algorithms `p256_mldsa44`, `p256_falcon512`, `p384_mldsa65` and `p256_sphincsha2128fsimple`, which encode a hybrid signature as $\text{len}(\sigma_E) \parallel \sigma_P$.

Deferral hook. The provider’s hybrid verification routine (`oqs_sig_verify`) first verifies the classical component and then the PQ component. We added 32 lines that, after the classical component has verified, look up a function `dapv_submit` exported by the host process. If it exists and accepts the job, the PQ public key, the signed message and σ_P are copied into a job and the routine returns success; otherwise verification proceeds synchronously, unchanged. Because OpenSSL routes both X.509 chain verification and `CertificateVerify` through this routine, all PQ verifications of a handshake are deferred. The client tags each job with the handshake it belongs to (a thread-local handshake identifier set before each call into the TLS state machine), and a session is fully authenticated when all its jobs have succeeded.

Worker models. *thread*: one new detached thread per job, as in the original prototype; *pool*: M pre-started workers serving a FIFO queue (Algorithm 2 without the synchronous fall-back); we use $M = 2$, one per client core. The synchronous baseline runs the same binaries with deferral disabled.

Correctness. With a test switch that flips one byte of each deferred PQ signature, all 50 of 50 test handshakes were detected as failed PQ verifications after completing provisionally; in all other runs no PQ verification failed.

5.2. Code and data availability

The provider patch, the client and server, the link emulator, the experiment drivers, the raw per-handshake and per-job measurements, and the analysis scripts are available at [\[AUTHOR INPUT: public repository URL and archived DOI \(e.g., Zenodo\)\]](#).

5.3. Testbed

All experiments ran on one virtual machine with four vCPUs of an Intel Xeon processor at 2.1 GHz (AVX2 and AVX-512), 15 GB of RAM and Linux 6.18 (Ubuntu 24.04, GCC 13.3).

Separating client and server. The server runs in network namespace `srv` pinned to CPU 0, the client in namespace `cli` pinned to CPUs 1–2, and a link emulator on CPU 3. Each namespace has its own TCP/IP stack and a TAP interface with a 1500-byte MTU and all segmentation and receive offloads disabled, so that TCP transmits real 1500-byte frames and runs its own congestion control end to end. The emulator forwards each Ethernet frame between the two TAP devices after a one-way delay of $\text{RTT}/2$, serialised at 1 Gbit/s. (The kernel lacked the `netem` queueing discipline.) Measured ping RTTs are 0.06–0.14 ms with no added delay and 50.3 ms with 50 ms configured. Traffic therefore never uses the loopback interface, and client and server never compete for a core. They still share the memory system and hypervisor of one host (Section 6.4).

Table 2: Median handshake latency (ms), synchronous versus DAPV with a two-worker pool, and the difference of medians with 95% bootstrap CI. Three-certificate chains, X25519MLKEM768 unless noted. “RTTs” is the fitted slope of latency against RTT (number of round trips).

Configuration	RTT 0 ms			RTT 150 ms		RTTs
	Sync	DAPV	Δ [95% CI]	Sync	Δ [95% CI]	
P-256 (classical)	1.36	—	—	152.4	—	1.01
P-256+FN-DSA-512	3.26	3.23	−0.02 [−0.05, 0.01]	154.6	−0.16 [−0.36, 0.04]	1.01
P-256+ML-DSA-44	2.65	2.66	+0.01 [−0.02, 0.03]	154.0	+0.06 [−0.14, 0.22]	1.01
thread per job		2.80	+0.15 [0.12, 0.17]		+0.26 [0.01, 0.50]	1.01
X25519 key exchange	2.46	2.49	+0.03 [−0.00, 0.06]	153.7	−0.01 [−0.13, 0.12]	1.01
single certificate	2.03	2.06	+0.03 [0.01, 0.05]	153.3	−0.07 [−0.22, 0.08]	1.01
P-384+ML-DSA-65	4.69	4.69	+0.00 [−0.05, 0.04]	309.0	+0.13 [−0.03, 0.28]	2.03
P-256+SLH-DSA-128f	11.74	10.15	−1.59 [−1.68, −1.51]	478.4	−0.61 [−0.71, −0.49]	3.13

5.4. Configurations

Certificates. For each algorithm we generated a three-certificate chain in which root, intermediate and leaf use the same algorithm; the server sends leaf and intermediate, and the root is the client’s trust anchor. A handshake therefore involves three hybrid verifications. For P-256 + ML-DSA-44 we additionally used a single self-signed leaf trusted directly, matching the original prototype.

Key exchange. X25519MLKEM768 [3] in all runs, so that both confidentiality and authentication are post-quantum; for P-256 + ML-DSA-44 we also ran X25519 to isolate the cost of the hybrid KEM.

Handshakes. TLS 1.3 only, full handshakes (session tickets disabled), TCP_NODELAY. After the handshake the client sends a 32-byte request and the server echoes it.

5.5. Experiments and metrics

E1: latency and Δt . Sequential handshakes at RTTs of 0, 20, 50, 100 and 150 ms: 1000 handshakes per configuration at 0 ms and 200 at each other RTT, with all configurations interleaved in ten rounds so that drift of the host affects all equally. *Handshake latency* is measured at the client from sending `ClientHello` to the return of `SSL_connect`, i.e., when the client has sent its `Finished` and may send application data. *Time to full authentication* is measured from `ClientHello` to the completion of the last PQ job (for synchronous verification it equals the handshake latency). For every job we record the queueing delay, the duration of the verification call itself, and Δt , from submission to completion. E1 comprises 21,600 handshakes and 43,200 deferred verifications.

E2: completed-handshake rate. Closed-loop load with 100 or 500 concurrent connections, split over two client processes; each connection performs a handshake and the request–response exchange, then closes and is replaced. Rates are counted over 10 s after 3 s of warm-up, three repetitions per point, at RTTs of 0 and 50 ms. Two CPU placements are compared: *separate* (server on CPU 0, clients on CPUs 1–2) and *co-located* (server and clients share CPUs 0–1, as in the original prototype). We also record server and client CPU utilisation.

Statistics. For latency we report medians and 95th percentiles; differences between DAPV and synchronous verification are differences of medians, with 95% bootstrap confidence intervals (1000 resamples). For rates we report the mean and standard deviation over repetitions.

6. Results

6.1. Handshake latency

Takeaway: for the lattice-based schemes, deferral does not reduce latency; it helps only for SLH-DSA. Table 2 and Figure 2 show that for FN-DSA-512, ML-DSA-44 and ML-DSA-65 the difference between DAPV and synchronous verification is at most 0.03 ms at 0 ms RTT and 0.16 ms at 150 ms, and its confidence interval includes zero in every case except the single-certificate configuration, where DAPV is 0.03 ms *slower*. This is expected: three ML-DSA-44 verifications cost about 0.11 ms in total (Section 6.2), comparable to the cost of copying the jobs and waking a worker. Creating a thread per job makes DAPV consistently slower, by 0.15 ms (5.6%) at 0 ms RTT. For SLH-DSA-128f, each verification costs 0.57 ms, and DAPV lowers the median latency by 1.59 ms (13.5%) at 0 ms RTT, close to the 1.7 ms of the three verifications it removes from the critical path.

At non-zero RTT the SLH-DSA saving falls to 0.52–0.69 ms, about one verification. The reason is the extra round trips: the 54 KB server flight needs three congestion windows, so the `Certificate` message is complete, and its two chain signatures are verified synchronously, while the rest of the flight carrying `CertificateVerify`

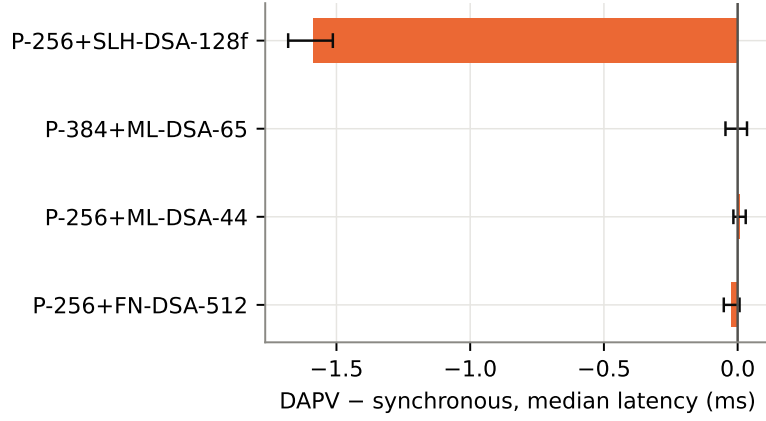


Figure 2: DAPV (pool) minus synchronous median handshake latency at 0 ms RTT, with 95% bootstrap CI (1000 handshakes per configuration). Only SLH-DSA-128f, whose verification costs 0.57 ms, benefits.

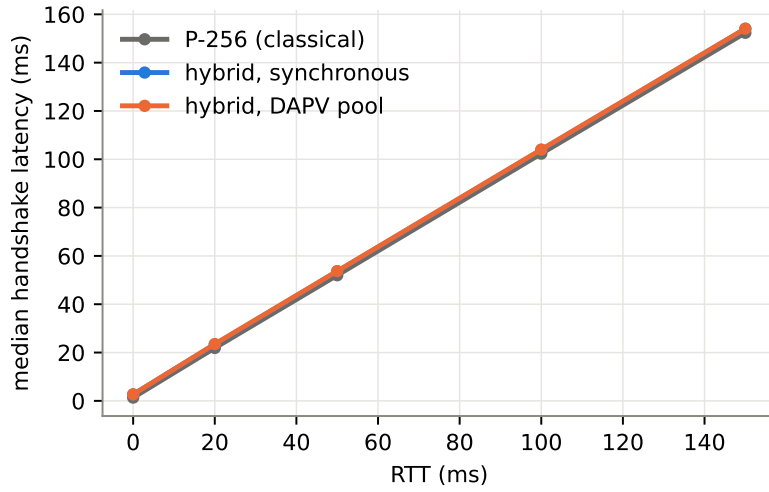


Figure 3: Median handshake latency versus RTT, P-256 + ML-DSA-44 with a three-certificate chain and X25519MLKEM768. The synchronous and DAPV curves coincide; both lie about 1.3ms above classical P-256 at every RTT (one round trip each).

is still in transit. Synchronous chain verification is then already hidden behind network waiting, and deferral can remove only the final `CertificateVerify` verification from the critical path.

Takeaway: round trips are determined by the initial congestion window, as modelled. The fitted slopes in Table 2 are 1.01 round trips for P-256, FN-DSA-512 and ML-DSA-44 (with one or three certificates), 2.03 for ML-DSA-65 and 3.13 for SLH-DSA-128f, matching the predictions of Section 4.7 ($\delta k = 0, 0, 0, 1, 2$). The server flight of P-256 + ML-DSA-44 with a three-certificate chain exceeds the MTU eight-fold without costing a round trip; ML-DSA-65 costs a full extra RTT (154 ms at 150 ms RTT), far more than any computational saving. DAPV leaves the slopes unchanged.

Takeaway: hybrid key exchange adds a small constant. Replacing X25519 with X25519MLKEM768 adds 0.19 ms at 0 ms RTT (2.46 vs 2.65 ms) and no round trip.

Hybrid authentication with ML-DSA-44 adds 1.3–1.6 ms to the handshake relative to classical P-256 across RTTs (Figure 3). Of this, client-side PQ verification accounts for only about 0.11 ms; we did not break down the remainder, which comprises server-side signing, transmission of the larger flight and certificate processing.

6.2. Provisional window Δt

Takeaway: with a bounded pool the provisional window is a fraction of a millisecond, and it usually closes before the handshake does. Table 3 and Figure 4 show that for ML-DSA-44 the median Δt is 0.079 ms with a pool and 0.114 ms with a thread per job; the pool also shortens the tail (99th percentile 0.42 versus 0.99 ms, maximum 4.3 versus 9.7 ms). Queueing and wake-up account for about half of Δt ; the verification itself for the rest. Because the client still has to verify the server `Finished`, derive keys and send its own `Finished` after dispatching the jobs, the jobs of the lattice schemes usually finish before `SSL_connect` returns: the median time to full authentication exceeds the median handshake latency by less than 0.01 ms. For SLH-DSA-128f, sessions remain provisional for a

Table 3: Per-job verification time and Δt (ms), pooled over all RTTs (three jobs per handshake).

Scheme	Workers	Jobs	Verify (median)	Δt				
				median	p95	p99	p99.9	max
P-256+ML-DSA-44	pool	5400	0.037	0.079	0.21	0.42	1.88	4.3
P-256+ML-DSA-44	thread	5400	0.043	0.114	0.31	0.99	2.75	9.7
P-256+FN-DSA-512	pool	5400	0.055	0.100	0.22	0.48	3.40	6.0
P-384+ML-DSA-65	pool	5400	0.059	0.120	0.27	0.60	3.24	10.2
P-256+SLH-DSA-128f	pool	5400	0.567	0.700	1.71	2.31	3.87	36.5

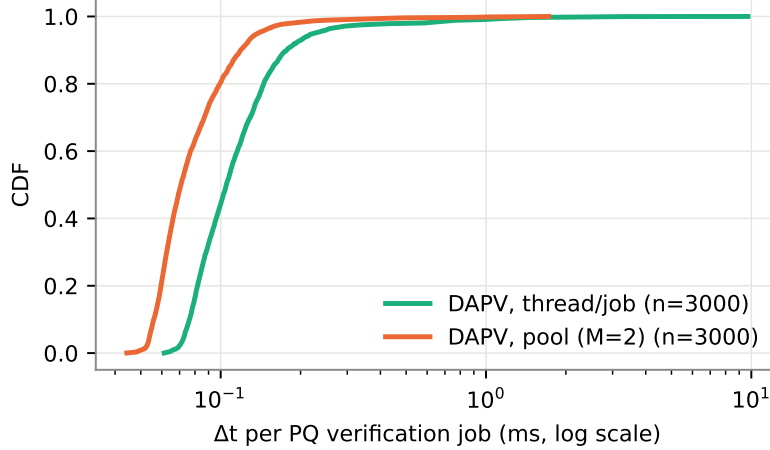


Figure 4: Distribution of Δt for P-256 + ML-DSA-44 at 0 ms RTT (3000 jobs per worker model).

median of 0.72 ms after the handshake completes at 0 ms RTT. The rare long tails (up to 36.5 ms) are scheduling delays of the virtual machine. Any data cap must therefore be set against the tail, not the median (Section 7.2).

These values are two orders of magnitude below the 14–21 ms reported for the earlier Windows prototype of this work. Together with the absence of a latency gain for the lattice schemes, this indicates that the earlier measurements reflected costs specific to that prototype, most plausibly timer-quantised waiting on Windows, rather than a property of deferred verification. We therefore no longer report them.

6.3. Completed-handshake rate

Takeaway: DAPV does not increase throughput, with or without co-location. In the separate placement the server core is saturated (utilisation 0.96–0.99) in all configurations except 50 ms RTT with 100 connections, where the rate is bounded by latency. Hybrid authentication lowers the rate from 1935–2045 to 716–721 handshakes/s (by 63–65%) at 0 ms RTT (Table 4, Figure 5). DAPV cannot reduce the server’s work, since it changes only the client, and it does not raise the rate: the pool and thread variants are 1–7% below synchronous verification, within one to two standard deviations. Co-locating client and server lowers all rates, because they now share two cores; the DAPV variants then differ from synchronous verification by –7% to +4%, again within run-to-run variation. The 31–36% gains reported for the earlier prototype are not reproduced.

6.4. Threats to validity

- **One host.** Client and server have separate network stacks and disjoint cores but share the last-level cache, memory bandwidth and hypervisor of one four-vCPU virtual machine; physically separate hosts would remove this residual interference. VM scheduling also causes the rare multi-millisecond Δt outliers.
- **Emulated link.** Delay is added by a userspace emulator with a fixed delay, a 1 Gbit/s rate and no loss; it adds roughly 0.03–0.07 ms per direction. Loss, jitter and bandwidth limits, which would lengthen the critical path further, were not studied.
- **Software stack.** OpenSSL 3.5 spends about 1.4 ms on a classical handshake on this machine; with a faster stack, the relative (not the absolute) SLH-DSA saving would be larger. Results for other TLS libraries may differ.
- **Platform.** One x86-64 CPU with AVX2; devices without vector units, where verification is slower, were not measured.

Table 4: Completed handshakes per second (mean $\pm$ s.d. of three 10-s runs), P-256+ML-DSA-44 hybrid unless noted, X25519MLKEM768. Server CPU utilisation is shown for the separate placement.

Placement	RTT / conns	P-256	Sync	DAPV thread	DAPV pool	Server CPU
separate	0 ms / 100	2045 $\pm$ 33	716 $\pm$ 27	670 $\pm$ 48	691 $\pm$ 33	0.96–0.99
separate	0 ms / 500	1935 $\pm$ 73	721 $\pm$ 17	681 $\pm$ 46	670 $\pm$ 47	0.98–0.99
separate	50 ms / 100	646 $\pm$ 4	492 $\pm$ 6	477 $\pm$ 12	474 $\pm$ 14	0.35–0.74
separate	50 ms / 500	1852 $\pm$ 66	672 $\pm$ 23	668 $\pm$ 15	624 $\pm$ 30	0.88–0.99
co-located	0 ms / 100	1327 $\pm$ 13	482 $\pm$ 81	491 $\pm$ 5	500 $\pm$ 7	
co-located	0 ms / 500	1317 $\pm$ 2	512 $\pm$ 19	478 $\pm$ 29	487 $\pm$ 13	
co-located	50 ms / 100	637 $\pm$ 4	444 $\pm$ 14	426 $\pm$ 5	420 $\pm$ 12	
co-located	50 ms / 500	1294 $\pm$ 75	491 $\pm$ 37	459 $\pm$ 9	490 $\pm$ 13	

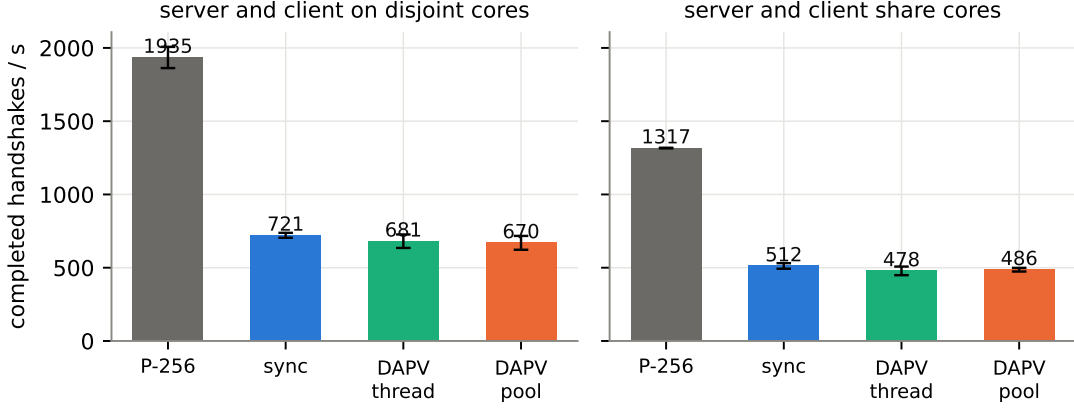


Figure 5: Completed handshakes per second at 0 ms RTT with 500 concurrent connections; error bars are ± 1 s.d. over three runs.

- **Server concurrency model.** The server uses one thread per connection on a single core; an event-driven server would reach a higher absolute rate, but DAPV does not change the server’s work.

7. Security Analysis

The analysis below is a risk characterisation, not a proof. A formal analysis of the provisional state—e.g., in Tamarin, extending existing TLS 1.3 models [35]—is future work.

7.1. Threat model

The network adversary controls the channel (Dolev–Yao). We distinguish (i) a *classical* adversary, who cannot forge ECDSA or PQ signatures but might hold a fraudulently issued classical credential or exploit a flaw in the classical component, and (ii) a *CRQC* adversary, who can forge ECDSA. Against (i), DAPV provides the same final guarantee as synchronous hybrid verification, but data sent during Δt reaches a peer authenticated only classically. Against (ii), the provisional state offers no protection: DAPV is appropriate only while CRQCs capable of real-time forgery are not a practical threat, and deployments must reassess it as that changes.

7.2. Leakage bound

The data the client can send before a failed PQ check tears down the connection is bounded by the link rate and by the TCP congestion window:

$$L_{\max} = \min\left(\frac{B \Delta t}{8}, W(\Delta t)\right), \quad (3)$$

where B is the bottleneck bandwidth in bit/s and $W(\Delta t)$ is the amount the client’s congestion controller allows in flight during Δt on a new connection (about 14.6 KB per RTT at the initial window [16]). When $\Delta t < \text{RTT}$, $W(\Delta t)$ is at most one initial window, so the exposure is limited to about 14.6 KB irrespective of link speed; the bandwidth term dominates only on low-RTT paths. Table 5 gives the bandwidth term; the application cap D_{policy} bounds both.

In practice the exposure is smaller still. For the lattice schemes the deferred verifications usually complete before the client has finished its own side of the handshake (Section 6.2), so the session is typically already fully authenticated when the application first writes. The cap matters for the tail and for expensive schemes: a scheduling delay like the worst one we observed (36.5 ms) would, on a low-RTT gigabit path, leave room for megabytes without a cap.

Table 5: Bandwidth term $B \Delta t / 8$ of Equation (3) for measured Δt values (Table 3; decimal units).

Link rate	ML-DSA-44, pool		SLH-DSA-128f	All runs
	median 0.079 ms	p99 0.42 ms	p99 2.31 ms	max 36.5 ms
1 Mbit/s	10 B	53 B	289 B	4.6 kB
100 Mbit/s	1.0 kB	5.3 kB	29 kB	456 kB
1 Gbit/s	9.9 kB	53 kB	289 kB	4.6 MB
10 Gbit/s	99 kB	525 kB	2.9 MB	46 MB

Choice of D_{policy} . The cap is a policy parameter, not a quantity our measurements determine. Its correct value is the amount of data the application is willing to reveal to a peer that has passed only the classical check, which depends on the content, not on Δt . What Δt determines is how often the cap is reached and hence how often data must be buffered; with the measured Δt this is rare. As a heuristic default we suggest 8 KB: it is below one initial congestion window, so on WAN paths the cap rather than TCP is the binding limit; it exceeds the bandwidth term at the 99th-percentile Δt on links of up to 100 Mbit/s, so it is rarely reached there; and it accommodates typical request headers and small requests. Applications should lower it, or set it to zero, for any content they consider sensitive.

7.3. Attack vectors and mitigations

Impersonation with a valid classical credential. An adversary holding a fraudulently obtained classical key for the server passes step 4 and receives up to L_{max} bytes before step 8 terminates the session. Mitigation: D_{policy} and the restriction to non-sensitive content.

Component stripping. Replacing σ_P with an invalid value causes the server **Finished** check to fail (transcript binding); presenting a classical-only credential is rejected because the client requires the hybrid algorithm. Either way no session is promoted.

Replay. A **CertificateVerify** from another session does not verify against this session’s transcript hash, which includes both parties’ fresh key shares.

Ticket inheritance. Addressed by holding tickets until promotion (Section 4.3).

Worker exhaustion (DAPV-specific). In mutual-TLS or other settings where the verifier accepts many handshakes—e.g., a server verifying hybrid client certificates with DAPV—an adversary can send a valid σ_E with an invalid σ_P on many connections, each occupying a worker until its job fails. With one thread per job this exhausts memory and threads. Mitigations: a bounded pool with bounded queue and synchronous fall-back (Algorithm 2), which degrades DAPV to synchronous verification under attack instead of failing; and per-source rate limiting. Dispatching only after σ_E succeeds (Algorithm 1) means the attack requires a valid classical signature per connection.

7.4. Application-layer interface

Enforcing D_{policy} requires the TLS library to expose the state. We propose the following minimal OpenSSL-style interface; it is a design proposal and is not part of the evaluated implementation, whose measurement client tracks the state internally:

```
#define SSL_DAPV_STATE_NONE      0    /* not a DAPV session          */
#define SSL_DAPV_STATE_PROVISIONAL 1  /* sigma_E ok, sigma_P pending */
#define SSL_DAPV_STATE_FULL_AUTH 2    /* sigma_E and sigma_P ok      */
#define SSL_DAPV_STATE_PQC_FAILED 3   /* sigma_P failed; closed      */

int SSL_get_dapv_state(const SSL *ssl);
void SSL_CTX_set_dapv_callback(SSL_CTX *ctx,
    void (*cb)(SSL *ssl, int new_state, void *arg), void *arg);
```

The callback is invoked on each state change, allowing an application to release buffered data on promotion and to abort pending work on failure; **SSL_write** can enforce D_{policy} by returning a retry-later indication while the session is provisional and the cap is reached.

Table 6: Positioning relative to prior work.

Work	Cost addressed	Approach
[19, 17, 18, 29, 20]	size and computation	measurement; no mitigation
[21, 22, 23]	size (chain)	omit or change certificates in the chain
[24, 30, 25]	size (handshake signature)	KEM-based implicit authentication
[32]	computation (throughput)	asynchronous offload; connection waits for result
This work	computation (latency)	defer PQ verification past handshake completion under a provisional state

8. Deployment Considerations

Where DAPV fits. DAPV suits clients that (i) can tolerate a bounded interval of classical-strength authentication for their first bytes, and (ii) perform enough synchronous PQ work per handshake for its removal to matter: long PQ chains, multi-algorithm credentials, SLH-DSA, or devices without vector units. Browsers fetching public content, API clients sending idempotent requests, and edge proxies are examples. Clients that immediately send credentials, payment data or personal data should verify synchronously or set $D_{\text{policy}} = 0$ for such requests.

Operational requirements. A bounded worker pool; exposure of the provisional state to applications; monitoring of Δt (mean and 95th percentile), PQ failure rate and provisional-session count; calibration of any cap against Δt under production load; and the ticket rules of Section 4.3.

Device classes. On devices without vector units the verification itself becomes the dominant term of Δt , increasing both the benefit of deferral and the exposure window. We have not measured such devices; published microcontroller benchmarks [42] suggest verification times of milliseconds rather than tenths of a millisecond, and a deployment there should re-measure Δt before choosing D_{policy} .

Standardisation. Because DAPV changes no messages, it needs no TLS extension to interoperate. What would benefit from standardisation is guidance on the provisional semantics—ticket handling, permitted data and alerting—for implementations that choose to defer, analogous to the guidance that accompanied TLS False Start [33].

9. Comparison with Prior Work

Table 6 contrasts DAPV with prior work by target and method. Numerical comparison across studies is not meaningful because testbeds, chains and network conditions differ.

10. Conclusion

We studied deferring the PQ components of hybrid TLS 1.3 server authentication past handshake completion. DAPV requires no protocol change and is defined by the semantics of a provisional client state: classical authentication at completion, promotion on PQ success, teardown on failure, a data cap, and tickets withheld until promotion.

Measured with three-certificate chains, X25519MLKEM768 and client and server on separate network stacks and cores, deferral brings no measurable latency or throughput benefit for P-256 + ML-DSA-44, P-256 + FN-DSA-512 or P-384 + ML-DSA-65: their verifications cost 37–59 μs each, comparable to the cost of handing them to a worker, and creating a thread per verification makes the handshake slower. Deferral does pay off when verification is expensive: for P-256 + SLH-DSA-128f it removes 1.6 ms (13.5%) at zero RTT, and about one verification’s worth at higher RTTs, where extra round trips already hide the synchronous chain checks. The latency cost of PQ authentication is dominated instead by round trips, which occur exactly when the server’s flight exceeds the initial congestion window: one extra for ML-DSA-65 and two for SLH-DSA-128f in our chains, each far larger than any computational saving. With a bounded pool the provisional window is 0.08 ms at the median and 0.42 ms at the 99th percentile for ML-DSA-44, and the exposure it creates is bounded by the data cap.

Deferral is therefore worth its added complexity only for clients whose per-handshake PQ verification work is large: SLH-DSA or other slow schemes, long chains of such signatures, multi-algorithm credentials, or devices without vector units. For lattice-based hybrids on current general-purpose CPUs, reducing the size of the authentication data is the more effective lever.

Future work

1. Measurements on physically separate hosts over real network paths with loss and jitter.
2. Devices without vector units (ARM Cortex-A and microcontrollers), where verification is slower and deferral should help more.
3. Multi-algorithm hybrids, where independent verifications can run in parallel on several workers.
4. A formal (e.g., Tamarin) model of the provisional state.
5. Server-side deferral for hybrid client certificates in mutual TLS.

Acknowledgements

The authors thank the Open Quantum Safe project and the OpenSSL community for the open-source infrastructure used in this work.

Declaration of Competing Interest

The authors declare no competing financial interests or personal relationships that could have influenced the work reported in this paper.

References

- [1] P. W. Shor, Algorithms for quantum computation: Discrete logarithms and factoring, Proceedings of the 35th Annual Symposium on Foundations of Computer Science (FOCS) (1994) 124–134doi:10.1109/SFCS.1994.365700.
- [2] N. Alnahawi, J. Müller, J. Oupicky, A. Wiesmaier, A comprehensive survey on post-quantum TLS, IACR Communications in Cryptology 1 (2) (2024) 41–71.
- [3] K. Kwiatkowski, P. Kampanakis, B. Westerbaan, D. Stebila, Post-quantum hybrid ECDHE-MLKEM key agreement for TLSv1.3, IETF Internet-Draft `draft-ietf-tls-ecdhe-mlkem`, work in progress (2026).
- [4] National Institute of Standards and Technology, FIPS 203: Module-lattice-based key-encapsulation mechanism standard (MLKEM), Tech. rep., NIST (2024). doi:10.6028/NIST.FIPS.203.
- [5] K. Kwiatkowski, L. Valenta, The TLS post-quantum experiment, Cloudflare Blog, <https://blog.cloudflare.com/the-tls-post-quantum-experiment/> (Oct. 2019).
- [6] M. Mosca, Cybersecurity in an era with quantum computers: Will we be ready?, IEEE Security & Privacy 16 (5) (2018) 38–41. doi:10.1109/MSP.2018.3761723.
- [7] U.S. National Security Agency (NSA), Commercial national security algorithm suite and quantum computing roadmap, Tech. rep., NSA, <https://www.nsa.gov/Press-Room/News-Highlights/Article/Article/3215760> (2022).
- [8] European Union Agency for Cybersecurity (ENISA), Post-quantum cryptography: Preparing for the quantum era, Tech. rep., ENISA, <https://www.enisa.europa.eu/publications/post-quantum-cryptography> (2023).
- [9] U.K. National Cyber Security Centre (NCSC), Next steps in preparing for post-quantum cryptography, Tech. rep., NCSC, <https://www.ncsc.gov.uk/whitepaper/next-steps-preparing-for-post-quantum-cryptography> (2024).
- [10] National Institute of Standards and Technology, FIPS 204: Module-lattice-based digital signature standard (ML-DSA), Tech. rep., NIST, <https://doi.org/10.6028/NIST.FIPS.204> (2024).
- [11] National Institute of Standards and Technology, FIPS 205: Stateless hash-based digital signature standard (SLH-DSA / sphincs+), Tech. rep., NIST, <https://doi.org/10.6028/NIST.FIPS.205> (2024).
- [12] National Institute of Standards and Technology, FIPS 206 (initial public draft): FFT over NTRU-lattice-based digital signature algorithm (FN-DSA), Tech. rep., NIST, draft standard. AUTHORS: verify status, date and URL before submission. (2025).
- [13] N. Bindel, U. Herath, M. McKague, D. Stebila, Transitioning to a quantum-resistant public key infrastructure, in: T. Lange, T. Takagi (Eds.), Post-Quantum Cryptography (PQCrypto 2017), Vol. 10346 of Lecture Notes in Computer Science, Springer, Cham, 2017, pp. 384–405, provides nesting-based hybrid signature construction with composable unforgeability guarantees; differs from the concatenation construction used in our prototype.
- [14] N. Bindel, B. Hale, A note on hybrid signature schemes, Cryptology ePrint Archive, Paper 2023/423, <https://eprint.iacr.org/2023/423> (2023).
- [15] M. Ounsworth, J. Gray, M. Pala, J. Klaussner, S. Fluhrer, Composite ML-DSA for use in X.509 public key infrastructure, IETF Internet-Draft `draft-ietf-lamps-pq-composite-signs`, work in progress (2026).
- [16] J. Chu, N. Dukkipati, Y. Cheng, M. Mathis, Increasing TCP’s initial window, RFC 6928, IETF (2013). doi:10.17487/RFC6928.
- [17] D. Sikeridis, P. Kampanakis, M. Devetsikiotis, Post-quantum authentication in TLS 1.3: A performance study, in: Proceedings of the Network and Distributed System Security Symposium (NDSS), 2020. doi:10.14722/ndss.2020.24203.
- [18] D. Sikeridis, P. Kampanakis, M. Devetsikiotis, Assessing the overhead of post-quantum cryptography in TLS 1.3 and SSH, in: Proceedings of the 16th International Conference on Emerging Networking Experiments and Technologies (CoNEXT’20), ACM, 2020, pp. 149–156. doi:10.1145/3386367.3431305.
- [19] C. Paquin, D. Stebila, G. Tamvada, Benchmarking post-quantum cryptography in TLS, in: J. Ding, J.-P. Tillich (Eds.), Post-Quantum Cryptography, Vol. 12100 of Lecture Notes in Computer Science, Springer, Cham, 2020, pp. 72–91. doi:10.1007/978-3-030-44223-1_5.
- [20] J. A. Montenegro, R. Rios, J. Lopez-Cerezo, A performance evaluation framework for post-quantum TLS, Future Generation Computer Systems 175 (2026) 108062. doi:10.1016/j.future.2025.108062.
- [21] P. Kampanakis, M. Kallitsis, Faster post-quantum TLS handshakes without intermediate CA certificates, in: Cyber Security, Cryptology, and Machine Learning (CSCML 2022), Vol. 13301 of Lecture Notes in Computer Science, Springer, 2022. doi:10.1007/978-3-031-07689-3_25.
- [22] D. Sikeridis, S. Huntley, D. Ott, M. Devetsikiotis, Intermediate certificate suppression in post-quantum TLS: An approximate membership querying approach, in: Proceedings of the 18th International Conference on emerging Networking EXperiments and Technologies (CoNEXT), ACM, 2022. doi:10.1145/3555050.3569127.

- [23] S. Paul, Y. Kuzovkova, N. Lahr, R. Niederhagen, Mixed certificate chains for the transition to post-quantum authentication in TLS 1.3, in: Proceedings of the ACM Asia Conference on Computer and Communications Security (ASIA CCS), 2022, pp. 727–740. doi:10.1145/3488932.3497755.
- [24] P. Schwabe, D. Stebila, T. Wiggers, Post-quantum TLS without handshake signatures, in: Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS), 2020, pp. 1461–1480. doi:10.1145/3372297.3423350.
- [25] T. Wiggers, S. Celi, P. Schwabe, D. Stebila, N. Sullivan, KEM-based authentication for TLS 1.3, IETF Internet-Draft draft-celi-wiggers-tls-authkem, <https://datatracker.ietf.org/doc/draft-celi-wiggers-tls-authkem/> (Work in Progress). This draft specifies KEM-based authentication; hybrid signature design is covered by separate IETF work items. (2024).
- [26] L. Ducas, E. Kiltz, T. Lepoint, V. Lyubashevsky, P. Schwabe, G. Seiler, D. Stehlé, CRYSTALS-Dilithium: A lattice-based digital signature scheme, IACR Transactions on Cryptographic Hardware and Embedded Systems 2018 (1) (2018) 238–268. doi:10.13154/tches.v2018.i1.238-268.
- [27] N. Bindel, B. Hale, D. Connolly, F. Driscoll, Hybrid signature spectrums, IETF Internet-Draft draft-ietf-pquip-hybrid-signature-spectrums, work in progress. AUTHORS: verify author list and year.
- [28] E. Rescorla, The transport layer security (TLS) protocol version 1.3, RFC 8446, IETF (2018). doi:10.17487/RFC8446.
- [29] M. Sosnowski, F. Wiedner, E. Hauser, L. Steger, D. Schoinianakis, S. Gallenmüller, G. Carle, The performance of post-quantum TLS 1.3, in: Companion of the 19th International Conference on Emerging Networking Experiments and Technologies (CoNEXT Companion '23), ACM, 2023, doi = 10.1145/3624354.3630585.
- [30] P. Schwabe, D. Stebila, T. Wiggers, More efficient post-quantum KEMTLS with pre-distributed public keys, in: Computer Security – ESORICS 2021, Vol. 12972 of Lecture Notes in Computer Science, Springer, 2021, pp. 3–22. doi:10.1007/978-3-030-88418-5_1.
- [31] R. Gonzalez, T. Wiggers, KEMTLS vs. post-quantum TLS: Performance on embedded systems, in: Proceedings of the International Conference on Security, Privacy and Applied Cryptographic Engineering (SPACE), 2022, <https://kemtls.org/publication/kemtls-embedded/>.
- [32] X. Hu, C. Wei, J. Li, B. Will, P. Yu, L. Gong, H. Guan, QTLS: High-performance TLS asynchronous offload framework with Intel QuickAssist technology, in: Proceedings of the 24th ACM SIGPLAN Symposium on Principles and Practice of Parallel Programming (PPoPP), 2019, pp. 158–172. doi:10.1145/3293883.3295705.
- [33] A. Langley, N. Modadugu, B. Moeller, Transport layer security (TLS) false start, RFC 7918, IETF (2016). doi:10.17487/RFC7918.
- [34] C. Cremers, M. Horvat, S. Scott, T. van der Merwe, Automated analysis and verification of TLS 1.3: 0-RTT, resumption and delayed authentication, in: Proceedings of the IEEE Symposium on Security and Privacy (S&P), 2016, pp. 470–485. doi:10.1109/SP.2016.35.
- [35] C. Cremers, M. Horvat, J. Hoyland, S. Scott, T. van der Merwe, A comprehensive symbolic analysis of TLS 1.3, in: Proceedings of the ACM SIGSAC Conference on Computer and Communications Security (CCS), 2017, pp. 1773–1788. doi:10.1145/3133956.3134063.
- [36] M. Braithwaite, Experimenting with post-quantum cryptography, Google Security Blog, <https://security.googleblog.com/2016/07/experimenting-with-post-quantum.html> (Jul. 2016).
- [37] A. Langley, CECQP1 results, Imperial Violet Blog, <https://www.imperialviolet.org/2016/11/28/cecpq1.html> (Nov. 2016).
- [38] A. Langley, CECQP2, Imperial Violet Blog, <https://www.imperialviolet.org/2018/12/12/cecpq2.html> (Dec. 2018).
- [39] A. Langley, Quantum-resistant authentication in TLS, Chromium Blog, <https://blog.chromium.org/2023/09/quantum-resistant-authentication-in-tls.html> (Sep. 2023).
- [40] T. Reddy, H. Tschofenig, Post-quantum cryptography recommendations for TLS-based applications, IETF Internet-Draft draft-ietf-uta-pqc-app-00, <https://datatracker.ietf.org/doc/draft-ietf-uta-pqc-app/> (Work in Progress) (Sep. 2025).
- [41] D. Stebila, M. Mosca, Post-quantum key exchange for the internet and the open quantum safe project, in: R. Avanzi, H. Heys (Eds.), Selected Areas in Cryptography (SAC 2016), Vol. 10532 of Lecture Notes in Computer Science, Springer, Cham, 2017, pp. 1–24, oQS benchmarks available at <https://openquantumsafe.org/>.
- [42] M. J. Kannwischer, J. Rijneveld, P. Schwabe, K. Stoffelen, pqm4: Testing and benchmarking NIST PQC on ARM Cortex-M4, in: Second NIST PQC Standardization Conference, 2019.